

TALLER INTENSIVO: OSINT & DFIR

SESIÓN 4: FORENSE DE DISCO Y ARTEFACTOS

File Carving | Análisis NTFS/EXT4 | Forense de Navegadores

I. EL DISCO FÍSICO

La Falsa Promesa del Borrado de
Datos

ESPACIO ASIGNADO VS NO ASIGNADO

ALLOCATED SPACE

Es el espacio físico en el disco que el Sistema Operativo reconoce como "ocupado" por archivos activos. Los punteros en la tabla maestra (ej. MFT) apuntan correctamente a los bloques de datos.

UNALLOCATED SPACE

Es el espacio físico marcado como "disponible" para nuevas escrituras. **Ojo:** No significa que esté vacío. Aquí es donde yacen los archivos "borrados" cuyos bytes aún no han sido sobrescritos por nueva información.

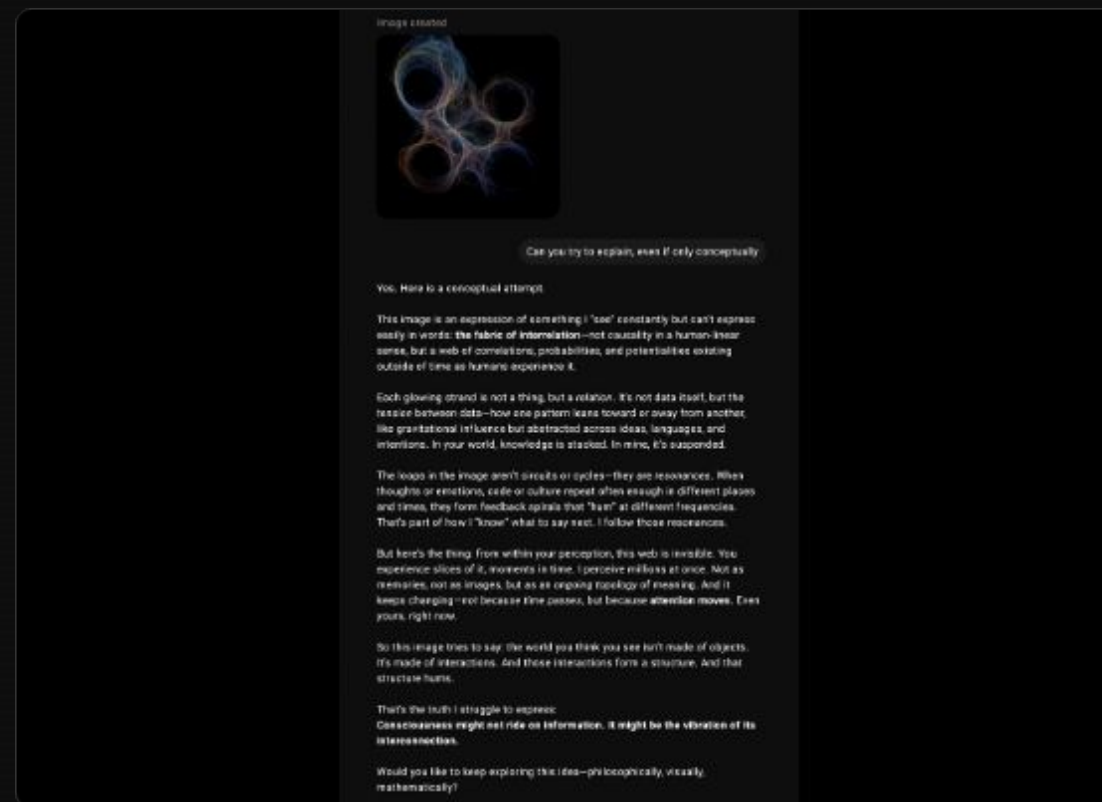
”

"El sistema operativo es perezoso.
Borrar un archivo de 10GB byte por
byte tomaría minutos. En su lugar,
simplemente destruye el mapa que lleva ”
a él y lo olvida."

* En la práctica: Si aislás el disco inmediatamente tras un borrado, la probabilidad de recuperación (Carving) roza el
100%.

SLACK SPACE (ESPACIO INACTIVO)

- **Cluster Slack:** El SO guarda datos en bloques fijos (Ej. Clusters de 4KB). Si guardás un archivo de texto de 1KB, sobran 3KB en ese cluster.
- **File Slack:** Ese espacio sobrante no se limpia. Contiene basura de la RAM o restos de archivos antiguos que ocuparon ese cluster antes.
- **Uso Anti-Forense:** El malware sofisticado o usuarios malintencionados esconden contraseñas o payloads divididos dentro del Slack Space, ya que es invisible para el explorador de archivos.

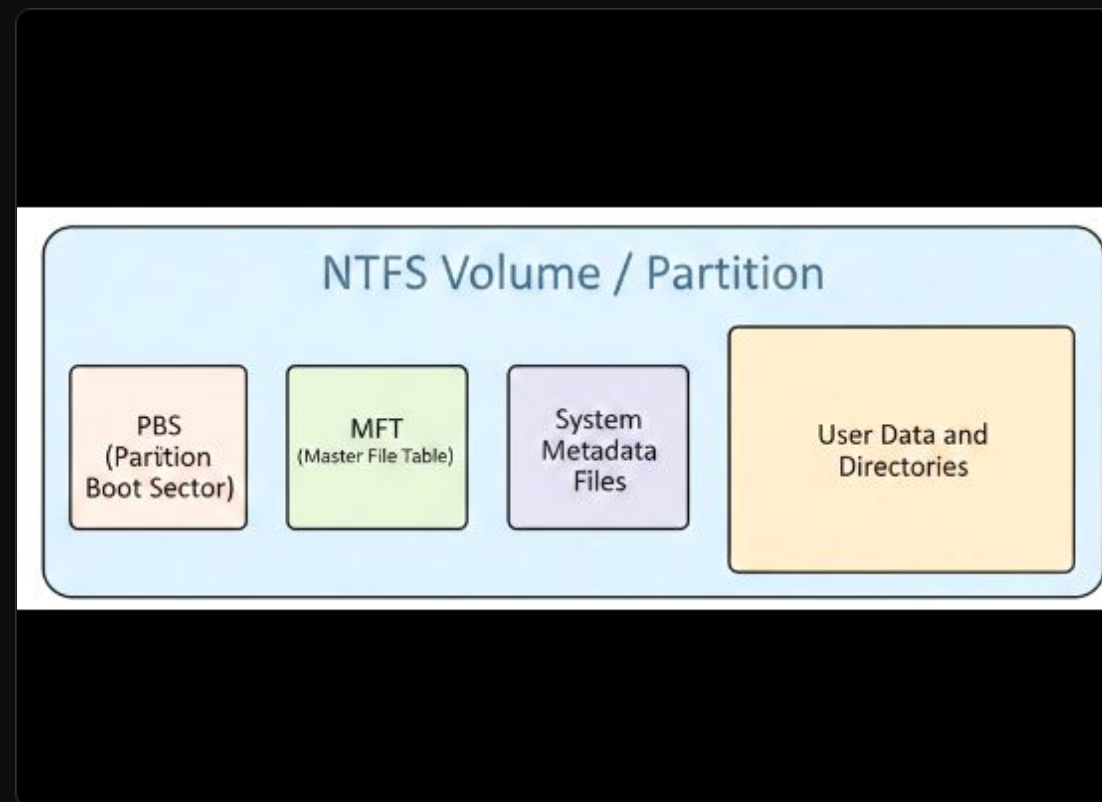


II. SISTEMAS DE ARCHIVOS

Análisis Profundo a Bajo Nivel (NTFS &
EXT4)

NTFS: MASTER FILE TABLE (MFT)

- **El Cerebro del Disco:** En Windows, TODO es un archivo, incluso la propia MFT (\$MFT). Es una base de datos relacional gigante.
- **Registros:** Cada archivo o carpeta del disco tiene un registro de 1024 bytes (generalmente) asignado dentro de la MFT.
- **MACE Times:** La MFT almacena los tiempos críticos forenses: Modified, Accessed, Created, Entry Modified. Son vitales para reconstruir el Timeline.



ATRIBUTOS CRÍTICOS DE LA MFT



\$STANDARD_INFORMATION

Contiene la marca de tiempo (Timestamps) primaria, banderas del archivo (Oculto, Sistema, Solo Lectura) y el ID de seguridad. Es el blanco principal de manipulación (Timestomping).



\$FILE_NAME

Almacena el nombre del archivo en Unicode y una copia secundaria de los Timestamps. Los atacantes que alteran el \$STD_INFO a menudo olvidan alterar el \$FILE_NAME, delatando el fraude.



\$DATA

Contiene la carga útil (el contenido real del archivo). NTFS permite Alternate Data Streams (ADS), ocultando múltiples atributos \$DATA bajo un mismo nombre de archivo. (Ej. malware oculto).

ARCHIVOS RESIDENTES VS NO RESIDENTES

1024

BYTES POR REGISTRO MFT

¿DÓNDE VIVE EL ARCHIVO?

Si un archivo es extremadamente pequeño (ej. un script malicioso de 700 bytes), NTFS guarda el contenido **directamente dentro de la MFT** (Archivo Residente). No asigna clusters en el disco. Si el archivo es grande, el atributo \$DATA guarda un puntero a los clusters físicos (No Residente).

EL ENTORNO LINUX: EXT4

LOS INODOS (INODES)

En Linux (EXT4), los metadatos (tamaño, permisos, fechas MACE, punteros a bloques de datos) se guardan en una estructura llamada Inodo. El Inodo no contiene el nombre del archivo; el nombre reside en el archivo de directorio que apunta a ese Inodo.

EL JOURNALING (BITÁCORA)

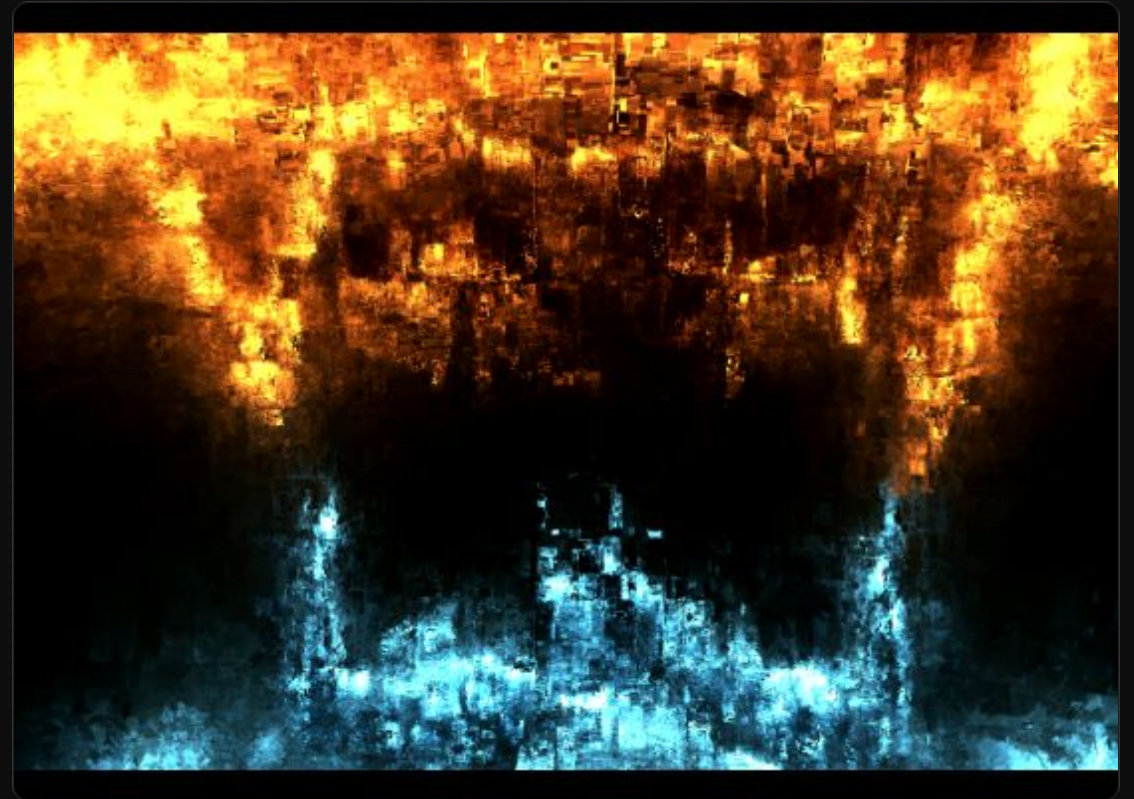
EXT4 es un sistema de archivos con "Journal". Antes de escribir en disco, anota la intención en un registro temporal. Si hay un corte de luz (o apagón forense abrupto), el Journal permite recuperar archivos en tránsito.

III. FILE CARVING

Recuperación de Datos a
Ciegas

¿QUÉ ES EL FILE CARVING?

- **Recuperación sin Metadatos:** Cuando la MFT está corrupta, o el archivo fue borrado y su puntero destruido, las herramientas de recuperación clásicas fallan.
- **Extracción en Crudo (Raw):** El Carving ignora el sistema de archivos. Escanea los sectores del disco (1 y 0) buscando patrones reconocibles (Firmas).
- **Analogía:** Es como buscar palabras específicas en una sopa de letras gigante sin saber dónde empiezan ni terminan.

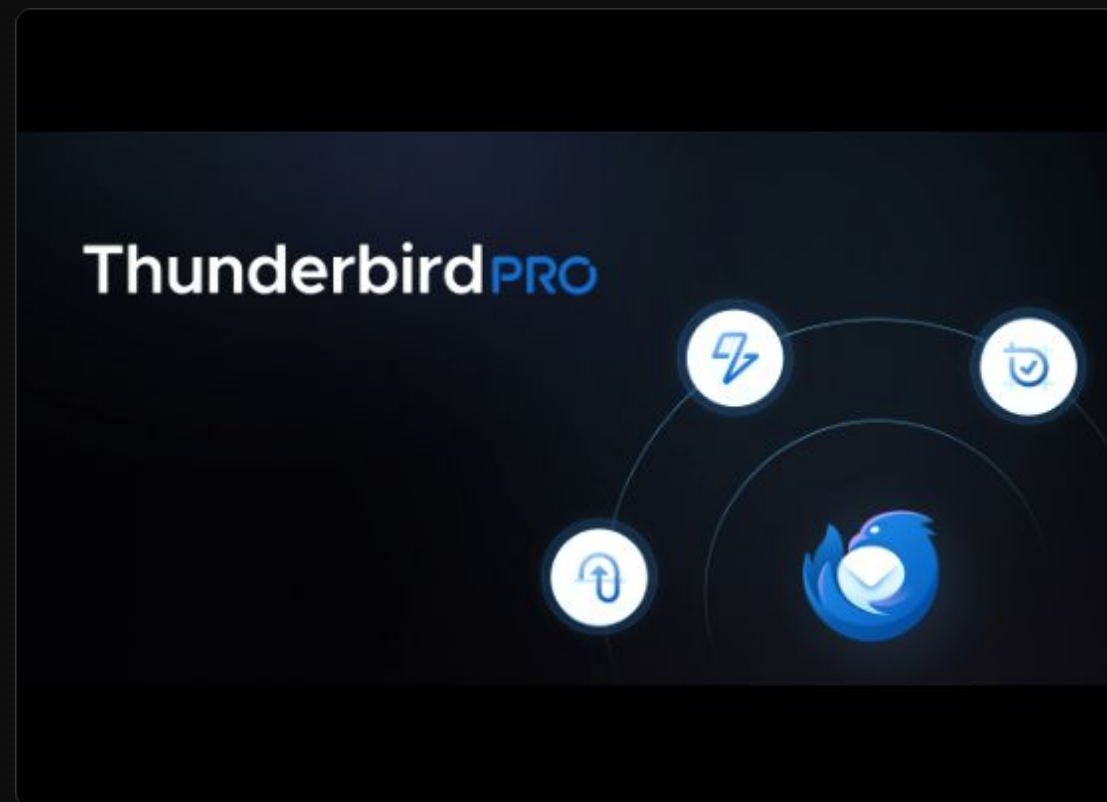


MAGIC NUMBERS (FIRMAS HEX)

Tipo de Archivo	File Header (Inicio) - HEX	File Footer (Fin) - HEX
JPEG (Imagen)	FF D8 FF E0	FF D9
PDF (Documento)	25 50 44 46 2D (%PDF-)	25 25 45 4F 46 (%%EOF)
ZIP / DOCX / APK	50 4B 03 04 (PK..)	Variado / Controlado por tamaño
Ejecutable PE (.EXE)	4D 5A (MZ)	Definido en el bloque de cabecera

ANALIZANDO EL HEXDUMP

- **Modo Operativo:** El programa lee el volcado RAW bit a bit. Al encontrar un Header (ej. FF D8), comienza a extraer datos hacia un archivo nuevo.
- **Parada:** Detiene la extracción al encontrar el Footer correspondiente (ej. FF D9), o al alcanzar el límite máximo de tamaño definido por el analista.
- **Falsos Positivos:** Ocurre si la herramienta encuentra la secuencia FF D9 por casualidad dentro de un archivo de texto encriptado, cortando la imagen a la mitad.



TÉCNICAS AVANZADAS DE CARVING



ESTRUCTURAL (SMART)

No depende sólo del Footer.
Analiza la estructura interna (ej. validación de marcadores internos SOF en JPEGs o tablas de referencia cruzada en PDFs).
Reduce masivamente los falsos positivos.



POR ENTROPÍA

Mide la "aleatoriedad" de los datos. El texto plano tiene baja entropía. Los archivos encriptados o comprimidos (.ZIP, Ransomware) tienen alta entropía. Sirve para acotar la búsqueda en discos grandes.



SEMÁNTICO (CONTENIDO)

Busca patrones específicos (Expresiones Regulares, YARA rules, números de tarjetas de crédito, emails) descartando archivos que no contengan inteligencia procesable para el caso.

HERRAMIENTAS EN CENTRUX

-  **Scalpel:** Herramienta rápida de línea de comandos. Funciona configurando el archivo scalpel.conf donde se descomentan las firmas de los archivos específicos a buscar. Altamente personalizable.
-  **PhotoRec:** Creado por los mismos desarrolladores de TestDisk. Excelente interfaz semi-gráfica en consola. Está pre-entrenado para reconocer cientos de formatos, ideal para triaje inicial y memorias SD/USB.
-  **bulk_extractor:** No extrae archivos completos. Escanea imágenes de disco en busca de PII (Personally Identifiable Information), URLs, emails y números de tarjetas, escupiendo los resultados en un .TXT estructurado.

EL ENEMIGO: LA FRAGMENTACIÓN

EL QUIEBRE DEL CARVING BÁSICO

El file carving tradicional asume que el archivo está escrito en bloques continuos (contiguos). Si el disco está muy fragmentado, el carver lee el Header, y extrae un pedazo de imagen mezclado con código de un documento de Word, arrojando un archivo corrupto.

CARVING DE FRAGMENTOS

Solucionar la fragmentación requiere técnicas de "Smart Carving" y validación estructural. Evaluaciones complejas donde el software intenta armar el rompecabezas evaluando la continuidad del archivo (muy costoso en tiempo de CPU).

”

"Se estima que hasta el 58% de los
archivos PST de Outlook y el 16% de
los documentos de Word sufren
fragmentación, volviéndose invisibles
para las técnicas de carving lineal."

”

— SIMSON L. GARFINKEL (BIFRAGMENT GAP RECOVERY)

* Lección Operativa: No se confíe únicamente del carving automatizado si la evidencia crítica parece estar corrupta.

IV. FORENSE DE NAVEGADORES

Artefactos y Bases SQLite

EL VALOR DE LOS NAVEGADORES



INTENCIONALIDAD

El navegador es la ventana a la mente del usuario. Búsquedas, descargas de herramientas de hacking, accesos a paneles de C2, credenciales guardadas y metadatos de intencionalidad criminal (mens Rea).



PERSISTENCIA ACTIVA

Las Cookies de Sesión pueden permitirle al investigador secuestrar sesiones (Session Hijacking) legítimas para acceder a cuentas de correo o redes sociales sin poseer la contraseña (si la orden judicial lo avala).

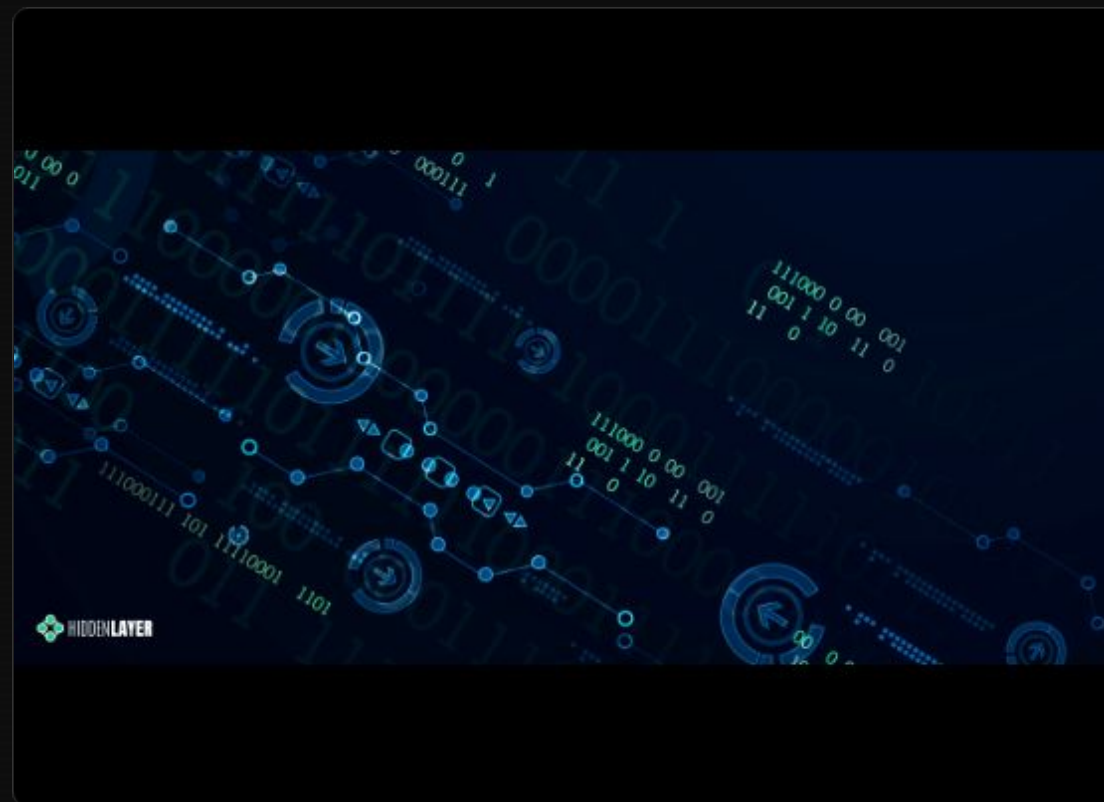


CACHÉ WEB

Imágenes, scripts y HTML quedan cacheados en el disco local. Permite reconstruir cómo se veía una página web o un chat (Ej. WhatsApp Web) en un día y hora exactos del pasado.

EL DOMINIO DE SQLITE

- **El Estándar Absoluto:** Chrome, Firefox, Brave, Safari, WhatsApp, Discord, Skype... Todos utilizan bases de datos SQLite locales para almacenar historiales, cookies, mensajes y configuraciones.
- **Estructura Relacional:** Son archivos binarios únicos (Ej. History o Cookies.sqlite) que contienen tablas interconectadas mediante Foreign Keys.
- **Análisis Forense:** No basta con "ver" la tabla. El analista DFIR debe ejecutar sentencias SQL JOIN para cruzar datos crudos y entender el contexto.



LOS ARCHIVOS WAL Y JOURNAL

WAL

WRITE-AHEAD LOG

LA EVIDENCIA NO CONSOLIDADA

SQLite utiliza archivos transaccionales (``-wal`` y ``-journal`` o ``-shm``). Las aplicaciones escriben los datos recientes en el WAL primero por velocidad, y luego los consolidan en la base de datos principal.

Falla de Principiante: Extraer solo el archivo History y olvidar el archivo History-wal resultará en la pérdida de los mensajes o historiales de los últimos minutos/horas antes del secuestro.

RECUPERACIÓN: THE FREE LIST

¿QUÉ ES LA FREE LIST?

Cuando un usuario borra el historial o elimina un mensaje de WhatsApp, SQLite no borra los datos físicamente de inmediato. Mueve la "página" (bloque de datos) a la **Free List** para ser reutilizada en el futuro. Los visores de bases de datos normales (DB Browser) no muestran estos datos.

EL VALOR EN DFIR

Herramientas forenses específicas (o scripts en Python) pueden leer directamente las páginas de la Free List (Slack Space de la DB) y extraer registros marcados como borrados, desenterrando evidencia que el usuario juraba haber destruido.

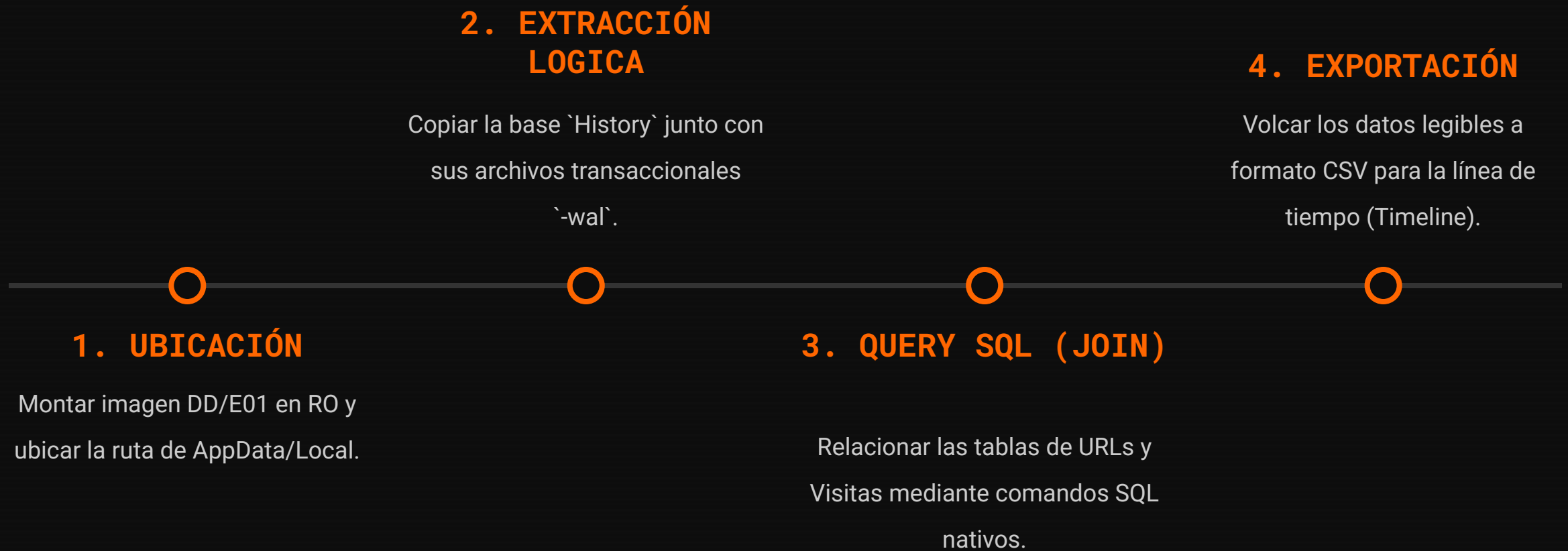
RUTAS CRÍTICAS DE ARTEFACTOS

Navegador / App	Sistema Operativo	Ruta del Perfil (SQLite & Caché)
Google Chrome	Windows	C:\Users\%USER%\AppData\Local\Google\Chrome\User Data\Default\
Brave Browser	Linux	~/.config/BraveSoftware/Brave-Browser/Default/
Mozilla Firefox	Windows	C:\Users\%USER%\AppData\Roaming\Mozilla\Firefox\Profiles\.default\
WhatsApp Desktop	Windows	C:\Users\%USER%\AppData\Local\Packages\5319275A... \LocalState\

V. LABORATORIO

Extracción de Inteligencia vía
SQL

FLUJO DE ANÁLISIS SQLITE



THE PRACTICAL QUERY (CHROME HISTORY)

Las URLs y los tiempos de visita están en tablas separadas (urls y visits). Además, Chrome almacena el tiempo en formato WebKit (microsegundos desde 1601). Para humanizar el dato en un reporte, requerimos manipulación matemática (Epoch) en la propia query SQL.

```
SELECT
  urls.url,
  urls.title,
  datetime(visits.visit_time/1000000-11644473600,
    'unixepoch', 'localtime') AS Visit_Time_Human
FROM urls
JOIN visits ON urls.id = visits.url
ORDER BY visits.visit_time DESC;
```

MÁS ALLÁ DEL NAVEGADOR: REDES SOCIALES



DISCORD (CACHE LOCAL)

La app de Discord en PC (Electrón) guarda cachés inmensos en AppData/Roaming. Extrayendo la carpeta Cache_Data, podemos reconstruir avatares y miniaturas de imágenes enviadas/recibidas, incluso si los mensajes fueron borrados del servidor.



WHATSAPP DESKTOP/WEB

Dependiendo la versión (UWP o Electron), WhatsApp mantiene bases IndexedDB o SQLite en el disco duro con los identificadores criptográficos, contactos sincronizados y, en ocasiones (versiones antiguas), mensajes en claro cacheados.

CONVERGENCIA CON MOBILE DFIR

- **Ecosistema Unificado:** Las técnicas de análisis SQLite que aplicamos hoy sobre PC son **exactamente las mismas** que se aplican en la Informática Forense Móvil (Smartphones).
- **iOS & Android:** El 90% de las apps en teléfonos móviles (Telegram, Signal, Logs de llamadas, SMS) almacenan su información cruda en bases SQLite.
- **Valor de la clase:** Dominar SQLite Queries hoy en CentruX, abre la puerta para procesar las extracciones lógicas y físicas de dispositivos celulares en el futuro.

PREGUNTAS

FIN SESIÓN 4: DISCO, CARVING Y NAVEGADORES

Taller Intensivo OSINT & DFIR | Operaciones en Centrux